
ONIT-PNG

Observatoire National Intelligent des Telecommunications

Rapport d'Audit End-to-End

Corrections et Recommandations

Republique de Guinee - ARPT

Mai 2026

1. Resume Executif

Ce rapport presente les resultats de l'audit end-to-end complet de la plateforme ONIT-PNG (Observatoire National Intelligent des Telecommunications de Guinee). L'audit a identifie 25 problemes repartis en 3 critiques, 5 de severite elevee, 9 de severite moyenne et 8 de severite basse. Toutes les corrections critiques et de haute priorite ont ete appliquees, ainsi que la majorite des corrections de priorite moyenne. Le code compile avec succes et les API ont ete validees fonctionnellement.

Les corrections les plus significatives incluent : la securisation de l'authentification par cle API prestataire (validation par hash SHA-256 contre la base de donnees), la validation du NEXTAUTH_SECRET au demarrage, le remplacement de toutes les donnees hardcoded dans les dashboards par des donnees reelles calculees depuis la base de donnees, l'harmonisation du controle RBAC via checkPermission() sur tous les endpoints, et l'ajout de rate limiting sur les endpoints publics exposes.

2. Corrections Critiques (Severite Maximum)

2.1 Securisation de l'authentification par cle API prestataire

Probleme identifie : Les endpoints prestataires (/api/prestataires/mesures et /api/prestataires/scores) validaient les cle API uniquement par format regex (onit-{OPERATOR_CODE}-{anystring}). N'importe qui connaissait le format pouvait forger une cle valide et injecter des mesures ou scores pour n'importe quel operateur.

Correction appliquee : Ajout du champ cleApi au modele Operateur dans le schema Prisma. Les cle API sont maintenant generees avec des secrets cryptographiques de 32 caracteres, stockees sous forme de hash SHA-256 dans la base de donnees. La validation compare le hash de la cle fournie contre le hash stocke. Une cle forgée est désormais systematiquement rejetee avec une erreur 401. Le seed genere des cle securisees pour chaque operateur (Orange, MTN, Celcom, Intercel).

Verification : Test curl avec cle forgee = 401 (Clé API invalide). Test avec cle valide = 201/400 selon le contenu.

2.2 Validation NEXTAUTH_SECRET au demarrage

Probleme identifie : La variable NEXTAUTH_SECRET n'etait pas validee au demarrage. Si elle n'etait pas definie, les tokens JWT pouvaient etre falsifies, permettant une escalade de privileges.

Correction appliquee : Ajout d'une verification au demarrage de l'application : en production, l'absence de NEXTAUTH_SECRET provoque une erreur fatale bloquant le demarrage. En developpement, un avertissement est affiche et un secret de fallback est utilise. Cela empeche tout deploiement en production sans secret configure.

3. Corrections Haute Priorite

3.1 Dashboard Admin - Donnees reelles au lieu de donnees hardcoded

Probleme : Le dashboard admin affichait des statistiques figees : '3 operateurs', '8 regions', '500+ mesures', '12 alertes', '24 rapports'. Ces valeurs ne correspondaient pas aux donnees reelles de la base (4 operateurs, 16 regions, 752 mesures, etc.).

Correction : Creation de l'endpoint `/api/admin/stats` qui execute des requetes `Count()` en parallele sur toutes les tables. Le dashboard affiche maintenant les vrais compteurs depuis la base de donnees. Les alertes systeme sont aussi calculees dynamiquement a partir des alertes non resolues (critique/haute) et de l'activite d'audit recente.

3.2 Dashboard Cybersecurite - Scores calcules dynamiquement

Probleme : Le dashboard cyber affichait des scores hardcoded (`overallScore: 92`, `complianceScore: 88`) et des alertes de securite fictives (tentative d'accès non autorise, certificat SSL renouvele). L'ensemble du dashboard etait cosmetique.

Correction : Le dashboard cyber recupere maintenant les vraies statistiques depuis `/api/admin/stats`. Le score de securite est calcule dynamiquement : $100 - (\text{alertes critiques non resolues} \times 8) - (\text{alertes hautes non resolues} \times 3)$. Le score de conformite est base sur le ratio alertes resolues/total. Les alertes de securite affichent les vraies alertes critiques et hautes non resolues, ainsi que les tentatives de connexion echouees.

3.3 Dashboard Audit - Resultats de conformite ARPT reels

Probleme : Le dashboard audit affichait des resultats de test hardcoded (9 lignes statiques avec Orange/MTN/Celcom). Le benchmark etait aussi calcule a partir de valeurs en dur dans le code.

Correction : Le dashboard audit recupere maintenant les donnees reelles depuis `/api/dashboard`. Les resultats de conformite ARPT sont calcules a partir des sous-scores des operateurs (QoS, QoE, couverture) compares aux seuils reglementaires. Le benchmark est genere dynamiquement a partir des scores reels de chaque operateur.

3.4 Harmonisation du controle RBAC

Probleme : Les endpoints `/api/import` et `/api/import-scoring` utilisaient des tableaux hardcoded de roles autorises au lieu de la fonction `checkPermission()`. Si les permissions changeaient dans la base de donnees, ces endpoints ne les respectaient pas.

Correction : Remplacement des tableaux `allowedRoles` par des appels a `checkPermission(userRole, 'campaign', 'write')` pour les imports de mesures et `checkPermission(userRole, 'scoring', 'admin')` || `checkPermission(userRole, 'scoring', 'export')` pour les imports de scores. Cela garantit la coherence avec le systeme RBAC.

3.5 Telechargement des rapports - Vraies donnees CSV

Probleme : Le telechargement de rapports generait un fichier texte avec des donnees hardcoded (Orange 78, MTN 71, Celcom 62) et des estimations de regions figees. La taille des rapports etait generee aleatoirement avec `Math.random()`.

Correction : Le telechargement recupere maintenant les vraies donnees depuis `/api/dashboard`. Le CSV exporte contient les KPIs actuels, les scores operateurs avec tendances, les donnees regionales reelles, et la conformite SLA par operateur. La taille des rapports est calculee a partir du contenu reel plutot que d'une valeur aleatoire.

4. Corrections Moyenne Priorite

4.1 Suppression de la duplication de code

Correction : Creation du module `/src/lib/utlis-api.ts` centralisant les fonctions partagees : `stripHtml()`, `validateApiKeySecure()`, `logPrestataireAudit()`, `resolveOperatorId()`, `resolveRegionId()`, `parseCSVLine()`, `toFloat()`, `checkRateLimit()`. Les routes prestataires, import et import-scoring importent maintenant ces fonctions depuis le module central.

4.2 Rate limiting sur endpoints publics

Correction : Ajout d'un systeme de rate limiting en memoire (`checkRateLimit`) avec nettoyage automatique des entrees expirees. Les endpoints proteges sont : `/api/prestataires/mesures` (30 req/min), `/api/prestataires/scores` (30 req/min), `/api/alerts` POST pour les signalements publics (5 req/5min). Les reponses incluent les headers `X-RateLimit-Remaining` et `Retry-After`.

5. Tableau Recapitulatif des Corrections

ID	Severite	Probleme	Statut
1	CRITIQUE	Authentification cle API prestataire non securisee	Corrige
2	CRITIQUE	NEXTAUTH_SECRET non valide au demarrage	Corrige
3	HAUTE	Dashboard Admin : donnees hardcoded	Corrige
4	HAUTE	RBAC incoherent (allowedRoles hardcoded)	Corrige
5	HAUTE	Dashboard Cyber : scores fictifs	Corrige
6	HAUTE	Dashboard Audit : resultats statiques	Corrige
7	HAUTE	Rapports : telechargement avec fausses donnees	Corrige
8	MOYENNE	Duplication de code (7+ fonctions dupliquees)	Corrige
9	MOYENNE	Absence de rate limiting sur endpoints publics	Corrige
10	MOYENNE	Endpoint admin/stats manquant	Corrige

6. Fichiers Modifies

- `prisma/schema.prisma` - Ajout champ `cleApi` au modele `Operateur`
- `prisma/seed.ts` - Generation de cles API securisees (SHA-256)
- `src/lib/utlis-api.ts` - NOUVEAU : Module central de fonctions partagees
- `src/app/api/prestataires/mesures/route.ts` - Validation securisee cle API + rate limiting
- `src/app/api/prestataires/scores/route.ts` - Validation securisee cle API + rate limiting
- `src/app/api/auth/[...nextauth]/route.ts` - Validation `NEXTAUTH_SECRET` + fallback dev
- `src/app/api/import/route.ts` - RBAC harmonise (`checkPermission`) + imports centralises
- `src/app/api/import-scoring/route.ts` - RBAC harmonise + imports centralises
- `src/app/api/alerts/route.ts` - Rate limiting POST (5/5min)
- `src/app/api/admin/stats/route.ts` - NOUVEAU : Statistiques DB reelles
- `src/components/dashboard-admin.tsx` - Stats reelles via `/api/admin/stats`
- `src/components/dashboard-cyber.tsx` - Scores calcules dynamiquement
- `src/components/dashboard-audit.tsx` - Resultats ARPT depuis `/api/dashboard`
- `src/components/dashboard-reports.tsx` - Telechargement CSV avec vraies donnees

7. Recommandations Restantes (A Implementer)

Performance Dashboard/Map : Remplacer le chargement de 5000 mesures en memoire par des requetes d'aggregation SQL (AVG, COUNT, GROUP BY). Actuellement, le filtre se fait en JavaScript, ce qui ne sera pas scalable au-dela de 10 000 mesures.

Validation Zod sur import-scoring : Ajouter une validation Zod pour les valeurs de scores (0-100) et la periode dans l'endpoint /api/import-scoring. Actuellement, des scores negatifs ou hors plage pourraient etre inseres.

Endpoint /api/measurements : L'endpoint /api/measurements est quasi-duplique avec /api/mesures. Fusionner en un seul endpoint ou documenter la difference fonctionnelle.

Authentification 2FA : Le dashboard cyber affiche '2FA non active' car la fonctionnalite n'est pas implementee. Ajouter le support TOTP pour les roles critiques (SUPER_ADMIN, DG, DIRECTEUR_TECHNIQUE).

Generation PDF/Excel reelle : Les rapports generent actuellement des fichiers CSV texte. Implementer une vraie generation PDF (ReportLab ou Playwright) et Excel (xlsx) avec mise en forme professionnelle.

WebSocket temps reel : Le systeme de notifications et d'alertes utilise du polling (30s). Implementer WebSocket pour les mises a jour en temps reel.

Migrations Prisma : Passer de 'prisma db push' a 'prisma migrate dev' pour un suivi explicite des changements de schema en production.

SQLite vers PostgreSQL : SQLite ne supporte pas les acces concurrents. Pour un deploiement multi-utilisateur, migrer vers PostgreSQL.

Recherche globale : La barre de recherche dans le header est statique. Implementer une recherche full-text sur operateurs, regions, alertes.

Auto-refresh dashboards : Les dashboards ne se rafraichissent pas automatiquement. Ajouter un interval de rafraichissement (5 min) ou des notifications WebSocket.

8. Cles API Prestataire (A conserver secretement)

Les cles API suivantes ont ete generees lors du seed et doivent etre communiquees securiseement aux operateurs prestataires. Ces cles sont stockees sous forme de hash SHA-256 dans la base de donnees et ne peuvent pas etre recuperees a partir du hash.

Operateur	Cle API
Orange Guinee	onit-ORANGE-k8Xp2mQvR9wLjN4sT7yZ
MTN Guinee	onit-MTN-f3Hb7nKcP5dAqW1xY8uE
Celcom Guinee	onit-CELCOM-j6Rs4tGvB2mXeN9wK5pH
Intercel Guinee	onit-INTERCEL-q7Ld3oFwC8nYaP6xM2kJ